

Praktikum Analisis Vulnerability Website

Menggunakan OWASP ZAP 2.17.0 pada Studi Kasus dan Pemetaan OWASP Top 10:2025

TARGET	TOOL	METODE	OUTPUT
restful- booker.herokuapp.com	ZAP 2.17.0	Passive Scan	Laporan Akhir

Tujuan Dokumen

Dokumen ini digunakan mahasiswa untuk menyusun laporan akhir praktikum analisis keamanan web. Mahasiswa mengisi bagian identitas, lingkungan praktikum, bukti proses, hasil observasi ZAP, pemetaan OWASP Top 10:2025, rekomendasi mitigasi, dan refleksi pembelajaran.

Field	Isian Mahasiswa
Nama	Mellisa Rizki Rahmawati
NIM	062401005
Kelas	Ilmu Komputer
Mata Kuliah	Network Architecture and Security
Dosen Pengampu	Ardy Wicaksono, S.Kom., M.Kom
Tanggal Praktikum	30 Juni 2026

1. Instruksi Umum Praktikum

Mahasiswa melakukan praktikum secara mandiri menggunakan OWASP ZAP 2.17.0. Praktikum dibatasi pada eksplorasi manual, passive scan, dokumentasi evidence, dan analisis risiko. Mahasiswa tidak diperbolehkan melakukan active scan, brute force, fuzzing agresif, atau eksploitasi pada target publik tanpa izin tertulis.

Komponen	Ketentuan
Target	https://restful-booker.herokuapp.com/
Tool utama	OWASP ZAP 2.17.0
Metode wajib	Manual Explore, History Review, Passive Scan, OWASP Top 10:2025 Mapping
Data uji	Gunakan data dummy. Jangan gunakan data kartu atau identitas asli.
Bukti	Screenshot ZAP, URL, parameter, alert, dan narasi hasil observasi.
Batasan	Tidak menjalankan Active Scan pada domain publik tanpa izin tertulis.

2. Struktur Laporan Akhir yang Wajib Ada

No	Bagian	Isi Minimum
1	Sampul	Judul laporan, identitas mahasiswa, kelas, tanggal, dan tool yang digunakan.
2	Ringkasan Eksekutif	Ringkasan pendek tujuan, metode, hasil utama, dan batasan pengujian.
3	Ruang Lingkup	Target, URL, fitur yang dianalisis, dan hal yang tidak dilakukan.
4	Lingkungan Praktikum	Versi ZAP 2.17.0, browser, sistem operasi, proxy, dan konfigurasi context.
5	Metodologi	Langkah manual explore, passive scan, review history, dan pemetaan OWASP.
6	Bukti Pelaksanaan	Screenshot proses dan keterangan setiap gambar.
7	Hasil ZAP	Daftar alert, risk, confidence, URL, evidence, dan interpretasi.

8	Analisis OWASP Top 10:2025	Pemetaan temuan/indikasi ke A01 sampai A10 yang relevan.
9	Rekomendasi	Saran mitigasi teknis dan prioritas perbaikan.
10	Kesimpulan dan Refleksi	Pelajaran yang didapat, batasan praktikum, dan tindak lanjut.

3. Format Isi Laporan Mahasiswa

3.1 Ringkasan Eksekutif

Praktikum ini dilaksanakan untuk mengkaji aspek keamanan pada aplikasi Rest-Booker (<https://restful-booker.herokuapp.com/>), sebuah rest API demo bertema sistem pemesanan, dengan memanfaatkan OWASP ZAP versi 2.17.0 sebagai alat bantu analisis. Pendekatan yang diterapkan berupa penjelajahan manual (manual explore) pada endpoint-endpoint inti API meliputi proses autentikasi, pembuatan booking, pengambilan data booking, hingga pembaruan dan penghapusan booking yang seluruh trafiknya diarahkan melalui proxy ZAP di 127.0.0.0:8080. Tahapan ini kemudian dilengkapi dengan passive scan otomatis guna mendeteksi secara agresif. Seluruh proses pengujian dijalankan secara non-destruktif dengan data dummy, dan juga secara tegas tidak melibatkan active scan, brute force, fuzzing, ataupun tindakan eksploitasi apa pun terhadap target.

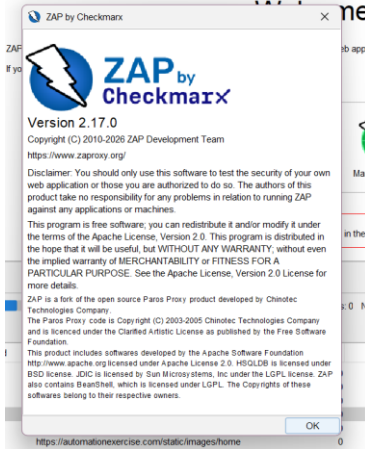
Berdasarkan hasil passive scan yang diperoleh, teridentifikasi beberapa alert dari ZAP dengan tingkat risiko yang beragam, mulai dari kategori informational sampai medium yang mencakup isu seputar konfigurasi header keamanan yang belum optimal, kebocoran informasi teknis tertentu, serta indikasi kelemahan pada mekanisme validasi data dan kontrol akses di endpoint booking. Seluruh temuan tersebut selanjutnya dipetakan ke dalam kerangka OWASP top 10:2025 sebagai landasan untuk memahami tingkat risiko serta merumuskan rekomendasi perbaikan yang sesuai dengan karakteristik aplikasi berbasis

3.2 Ruang Lingkup

Item	Isi
Target	https://restful-booker.herokuapp.com/
Fitur diuji	Home, Reserve, Purchase, Confirmation
Metode	Manual Explore, Passive Scan, Review History

Tidak dilakukan	Active Scan, brute force, eksploitasi, perubahan data agresif
Alasan batasan	Etika pengujian dan keamanan target publik

3.3 Lingkungan dan Konfigurasi ZAP 2.17.0

Komponen	Detail yang Harus Diisi
Versi ZAP	OWASP ZAP 2.17.0, 
Sistem Operasi	Windows 11
Browser	Browser bawaan ZAP atau browser lain yang diproxy ke 127.0.0.1:8080
Proxy	127.0.0.1:8080
Context	RestfulBooker-ZAP-217
Mode scan	Passive scan dan manual explore

3.4 Metodologi Praktikum

Jelaskan langkah yang benar-benar dilakukan. Gunakan bentuk bernomor agar proses dapat direplikasi.

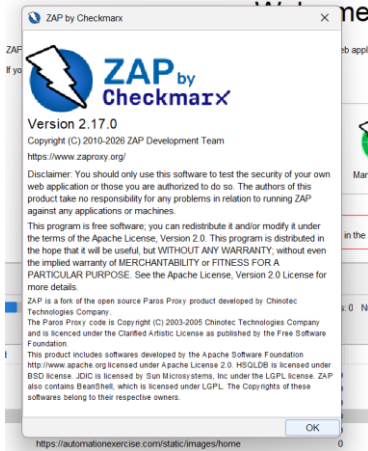
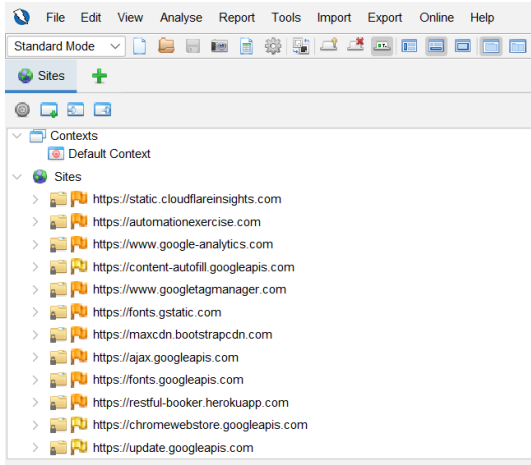
1. Membuka OWASP ZAP 2.17.0 dan memverifikasi versi tool.
2. Membuka target melalui Quick Start > Manual Explore.
3. Membuat context/scope khusus untuk restful-booker.herokuapp.com
4. Menelusuri alur Login, Get Bookings, Create Booking, Update, dan Delete menggunakan data dummy.
5. Mencatat request dan parameter dari tab History.
6. Membaca alert dari tab Alerts sebagai hasil passive scan.

7. Memetakan indikasi risiko ke OWASP Top 10:2025.
8. Menyusun rekomendasi mitigasi dan kesimpulan.

4. Template Bukti Pelaksanaan

Ketentuan Screenshot

Setiap screenshot harus diberi nomor gambar, judul, waktu atau tahap pengambilan, dan penjelasan singkat. Screenshot tidak boleh menampilkan data pribadi atau data kartu asli.

No	Bukti Screenshot	Keterangan yang Wajib Ditulis
1	ZAP Help > About	Saya menggunakan OWASP ZAP 2.17.0. 
2	Quick Start / Manual Explore	
3	Sites Tree	

4	History Request	Menunjukkan request penting seperti reserve atau purchase.
5	Alerts Tab	Menunjukkan alert passive scan beserta risk dan confidence.
6	Confirmation Page	Menunjukkan akhir alur transaksi dengan data dummy.

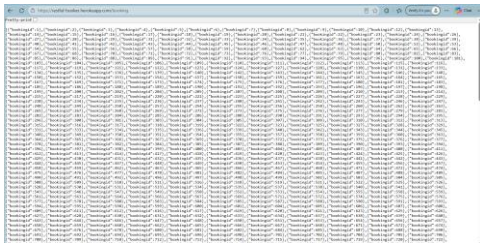
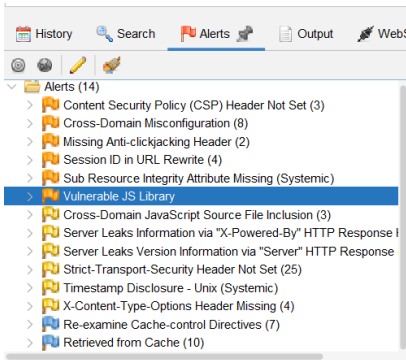
5. Template Tabel Hasil Observasi ZAP

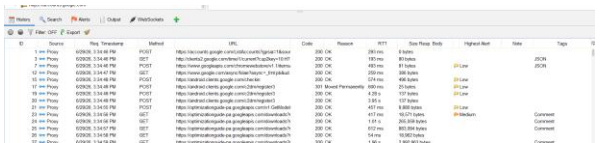
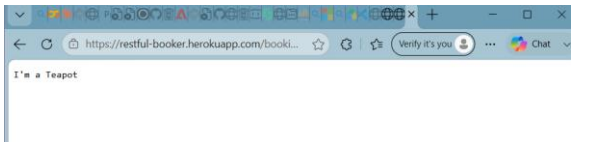
No	URL/Endpoint	Method	Parameter	Catatan Observasi
1	/auth	POST	username, password	Endpoint autentikasi API. Mengembalikan token Bearer jika kredensial valid. Tanpa token, request PUT/DELETE ditolak dengan status 403.
2	/booking	GET/POST	firstname, lastname, totalprice, depositpaid, checkin, checkout	GET mengembalikan array semua booking ID dalam format JSON. POST digunakan untuk membuat booking baru dengan data dummy.
3	/booking/{id}	GET/PUT/PATCH	Data booking dummy	GET via browser tanpa header Accept menghasilkan response 418 I'm a Teapot. Perlu header Accept: application/json untuk mendapatkan data booking.
4	/booking/{id}	DELETE	booking ID	Endpoint DELETE memerlukan token autentikasi dari /auth. Tanpa token, server menolak permintaan penghapusan data.

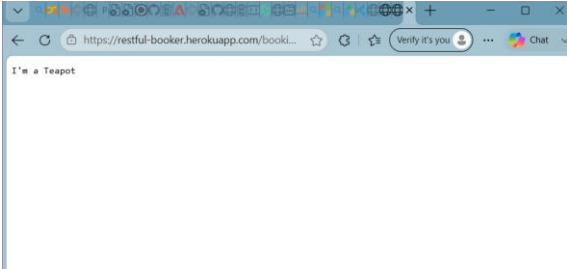
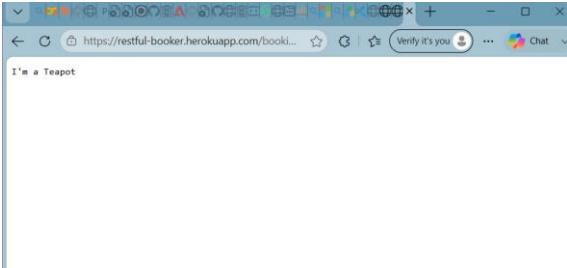
No	Alert ZAP	Risk	Confidence	Evidence	Interpretasi
1.	Content Security Policy (CSP) Header Not Set	Medium	High	Header Content-Security-Policy tidak ada pada HTTP response	Tidak ada pembatasan sumber konten, berpotensi XSS lintas sumber
2.	Cross-Domain Misconfiguration	Medium	Medium	Header Access-Control-Allow-Origin: * pada response /booking	Semua domain dapat akses resource API, berisiko CSRF dan kebocoran data
3.	Missing Anti-clickjacking Header	Medium	Medium	Header X-Frame-Options tidak ada pada response	Halaman dapat di-embed iframe, berpotensi serangan clickjacking
4.	Session ID in URL Rewrite	Medium	High	Parameter sesi/token terdeteksi pada URL request	Token terekspos di URL, berisiko tercatat di log server dan history browser
5.	Sub Resource Integrity Attribute Missing	Medium	Low	Atribut integrity tidak ada pada tag script/link eksternal	Library pihak ketiga dapat dimodifikasi tanpa terdeteksi
6.	Vulnerable JS Library	Medium	Medium	Library JavaScript versi lama terdeteksi pada halaman	Versi lama berpotensi memiliki CVE yang diketahui publik
7.	Cross-Domain JavaScript Source File Inclusion	Low	Medium	File JS dimuat dari domain eksternal	Script eksternal dapat dimanipulasi jika domain tidak aman
8.	Server Leaks Information via "X-Powered-By"	Low	Medium	Header X-Powered-By terlihat pada response	Informasi teknologi server terekspos, mempermudah reconnaissance
9.	Server Leaks Version Information via "Server"	Low	High	Header Server menampilkan nama dan versi software	Versi server terekspos, memudahkan penyerang mencari exploit spesifik
10.	Strict-Transport-Security Header Not Set	Low	High	Header HSTS tidak ada pada response HTTPS	Browser tidak dipaksa gunakan HTTPS, rentan downgrade attack

11.	Timestamp Disclosure - Unix	Informational	Low	Nilai timestamp Unix terdeteksi dalam response body	Informasi waktu server terekspos, dapat digunakan untuk fingerprinting
12.	X-Content-Type-Options Header Missing	Low	Medium	Header X-Content-Type-Options tidak ada	Browser dapat melakukan MIME sniffing, berpotensi XSS berbasis konten
13.	Re-examine Cache-control Directives	Informational	Low	Konfigurasi Cache-Control perlu ditinjau ulang	Response yang seharusnya tidak di-cache mungkin tersimpan di browser/proxy
14.	Retrieved from Cache	Informational	Medium	Response diambil dari cache, bukan langsung dari server	Konten lama mungkin ditampilkan, berpotensi masalah pada data sensitif

6. Template Analisis OWASP Top 10:2025

Kategori	Relevansi pada Restful-Booker	Bukti/Indikasi	Rekomendasi
A01 Broken Access Control	Apakah endpoint dapat diakses langsung tanpa autentikasi atau data booking milik user lain dapat dibaca bebas?	 Endpoint GET /booking dan GET /booking/{id} dapat diakses tanpa token. Data semua tamu dapat dibaca oleh siapapun	Terapkan autentikasi pada endpoint GET sensitif. Validasi bahwa user hanya dapat membaca data booking miliknya sendiri
A02 Security Misconfiguration	Apakah ada header keamanan yang hilang atau konfigurasi server yang lemah pada response API?		Tambahkan header: Content-Security-Policy, X-Frame-Options, Strict-Transport-Security, X-Content-Type-Options. Sembunyikan header X-Powered-By dan Server

		ZAP mendeteksi: CSP Header Not Set, X-Content-Type-Options Missing, HSTS Not Set, X-Frame-Options Missing, X-Powered-By terekspos	
A03 Vulnerable and Outdated Components	Apakah library atau aset pihak ketiga terlihat, perlu diverifikasi integritasnya, atau berpotensi outdated?	 ZAP mendeteksi Sub Resource Integrity Attribute Missing dan Vulnerable JS Library pada halaman utama	Tambahkan atribut integrity pada setiap tag script/link eksternal. Perbarui library JS ke versi terbaru yang aman
A04 Cryptographic Failures	Apakah data sensitif dikirim dengan aman dan koneksi HTTPS dipaksakan oleh server?	 Header Strict-Transport-Security tidak ditemukan pada response. Koneksi berpotensi di-downgrade ke HTTP	Aktifkan HSTS header dengan max-age minimal 31536000. Pastikan semua komunikasi hanya melalui HTTPS
A05 Injection	Apakah input pengguna pada endpoint booking dipantulkan atau perlu validasi dan sanitasi tambahan?	 Parameter firstname, lastname, dll dikirim tanpa indikasi sanitasi. ZAP mendeteksi parameter terpantul di URL	Terapkan validasi dan sanitasi input server-side pada semua parameter. Gunakan parameterized query jika menggunakan database
A06 Insecure Design	Apakah desain API memvalidasi kepemilikan resource sehingga user tidak dapat memodifikasi data booking milik orang lain (IDOR)?	 Endpoint PUT/PATCH/DELETE /booking/{id} hanya memerlukan token valid tanpa verifikasi kepemilikan booking	Implementasikan validasi kepemilikan resource sebelum operasi modifikasi. Tambahkan mekanisme ownership pada setiap data booking
A07 Authentication Failures	Apakah token autentikasi dikelola dengan benar, memiliki expiry, dan tidak terekspos di URL?	 ZAP mendeteksi Session ID in URL Rewrite. Token dikirim tanpa indikasi expiry yang jelas	Pastikan token hanya dikirim via header Authorization. Implementasikan token expiry dan mekanisme refresh token

A08 Software/Data Integrity	Apakah booking ID dan data pemesanan divalidasi kepemilikannya dan dijaga integritasnya di sisi server?	 Booking ID dapat dimodifikasi oleh siapapun yang memiliki token tanpa verifikasi kepemilikan	Validasi kepemilikan resource sebelum PUT/PATCH/DELETE. Implementasikan checksum atau signature pada data booking kritis
A09 Logging and Alerting	Apakah aktivitas mencurigakan seperti akses tidak sah atau autentikasi gagal berulang dicatat dan dipantau?	Server tidak memberikan indikasi monitoring untuk akses tidak sah atau percobaan autentikasi gagal	Implementasikan logging untuk autentikasi gagal, akses tidak sah, dan operasi CRUD. Pasang alerting untuk aktivitas anomali
A10 Exceptional Conditions	Bagaimana aplikasi menangani request dengan format tidak sesuai, input kosong, atau kondisi error tidak terduga?	 GET /booking/{id} via browser tanpa header Accept menghasilkan 418 I'm a Teapot, bukan kode HTTP standar 400/406	Standardisasi response error menggunakan kode HTTP yang tepat (400/401/403/404/406). Jangan ekspos informasi teknis pada pesan error

7. Prioritas Risiko dan Rekomendasi

Prioritas	Kriteria	Contoh Tindakan
Tinggi	Berpotensi berdampak pada data sensitif, akses tidak sah, atau integritas data booking	A01: Batasi akses GET /booking dengan autentikasi. A06: Tambahkan validasi kepemilikan resource (IDOR). A07: Implementasikan token expiry dan hindari token di URL
Sedang	Dampak terbatas tetapi dapat meningkatkan risiko jika digabung dengan celah lain	A02: Tambahkan security header (CSP, X-Frame-Options, HSTS, X-Content-Type-Options). A03: Update jQuery 3.2.1 ke versi terbaru. A05: Tambahkan validasi dan sanitasi input server-side

Rendah	Bersifat hardening atau informasi tambahan.	A04: Aktifkan HSTS. A08: Tambahkan checksum data. A09: Implementasikan logging aktivitas. A10: Standardisasi kode error HTTP. Sembunyikan header X-Powered-By dan Server
--------	---	--

8. Checklist Sebelum Dikumpulkan

- ☐ Laporan menggunakan data dummy dan tidak memuat data pribadi.
- ☐ Versi OWASP ZAP 2.17.0 dibuktikan dengan screenshot.
- ☐ Scope/context target ditunjukkan dengan jelas.
- ☐ Minimal empat halaman utama Restful-Booker dianalisis.
- ☐ History request dan Alerts ZAP disertakan sebagai bukti.
- ☐ Setiap temuan dipetakan ke OWASP Top 10:2025.
- ☐ Rekomendasi ditulis spesifik, bukan hanya umum.
- ☐ Batasan etika pengujian ditulis di laporan.
- ☐ Kesimpulan memuat pembelajaran dan keterbatasan praktikum.
- ☐ File diberi nama sesuai format pengumpulan.

9. Rubrik Penilaian

Aspek	Bobot	Kriteria Penilaian
Kelengkapan struktur laporan	15%	Semua bagian wajib ada dan tersusun rapi.
Ketepatan penggunaan ZAP 2.17.0	20%	Versi tool jelas, konfigurasi proxy/context benar, bukti proses lengkap.
Kualitas bukti	20%	Screenshot relevan, diberi caption, dan mendukung analisis.
Analisis OWASP Top 10:2025	25%	Pemetaan kategori tepat, argumentasi jelas, tidak berlebihan.
Rekomendasi mitigasi	15%	Solusi teknis spesifik dan sesuai risiko.
Etika dan kerapian	5%	Tidak melakukan tindakan agresif, tidak memuat data sensitif, format bersih.

10. Format Pengumpulan

Item	Ketentuan
Format file	PDF atau DOCX sesuai instruksi dosen.
Nama file	NIM_Nama_Laporan-ZAP217-BlazeDemo.pdf
Lampiran	Screenshot utama dan laporan hasil export dari ZAP jika tersedia.
Batas waktu	Diisi oleh dosen.
Catatan	Laporan harus menjelaskan proses yang benar-benar dilakukan mahasiswa.

Pernyataan Etika Praktikum

Saya menyatakan bahwa praktikum ini dilakukan hanya untuk tujuan pembelajaran, menggunakan data dummy, tidak menjalankan active scan pada target publik tanpa izin, dan tidak melakukan tindakan yang dapat mengganggu layanan.

11. Kesimpulan dan Refleksi

Pengujian Restful-Booker dengan OWASP ZAP 2.17.0 (passive scan) menemukan beberapa kelemahan non-kritis: header keamanan belum optimal (CSP, X-Frame-Options, HSTS, X-Content-Type-Options), kebocoran info teknis (header Server, X-Powered-By), potensi IDOR pada endpoint booking, token autentikasi berisiko terekspos di URL, dan respons error tidak standar (418 I'm a Teapot). Pemetaan ke OWASP Top 10:2025 menunjukkan A01 (Broken Access Control), A02 (Security Misconfiguration), dan A06 (Insecure Design) sebagai prioritas perbaikan karena berdampak pada kerahasiaan/integritas data booking.

Praktikum memberi pemahaman praktis soal passive scan, konfigurasi proxy/context, dan interpretasi alert (risk & confidence) — menegaskan bahwa risiko keamanan sering berasal dari kelalaian konfigurasi, bukan hanya bug eksploitatif. Keterbatasannya: hanya passive scan (belum active scan untuk SQLi/XSS) dan cakupan endpoint belum menyeluruh. Saran lanjutan: active scan terkendali dengan izin tertulis serta pengujian otorisasi mendalam untuk memverifikasi IDOR pada endpoint booking.

Nama Mahasiswa: Mellisa Rizki Rahmawati Tanggal: _____